

KINGSTON UNIVERSITY – FACULTY OF ENGINEERING, COMPUTING
AND THE ENVIRONMENT

Strengthening User Privacy through AI-Driven Risk Quantification and International Standards Alignment

MSc Project Proposal

A PROPOSAL PRESENTED TO THE SCHOOL OF COMPUTER SCIENCE AND
MATHEMATICS IN PARTIAL FULFILMENT OF THE REQUIREMENTS FOR THE DEGREE OF
MASTER OF SCIENCE IN ARTIFICIAL INTELLIGENCE

SUPERVISOR: Arshad Razi

SUBMITTED ON 30 JUNE 2026 BY

Jay Bell

Student ID: K2119852

Contents

List of Figures	ii
List of Tables	iii
Abstract	1
1 Introduction and Background	1
2 Aims and Objectives	2
3 Literature Review	3
3.1 AI for privacy-policy analysis	3
3.2 Privacy quantification and breach analytics	4
3.3 Standards and regulatory frameworks	4
3.4 Probabilistic risk modelling	5
3.5 Synthesis and gap	5
4 Technologies and Resources	5
5 Method and Work Plan	6
5.1 Research method	6
5.2 Schedule	7
5.3 Risk analysis and contingencies	7
5.4 Progress to date and feasibility	7
6 Ethics, Legal, Data Protection and Safety	8
7 Conclusion	9
References	10
A Appendix: Mapping of Objectives to Existing Repository Artefacts	I

List of Figures

1	High-level architecture of the proposed framework.	6
2	Project schedule (weekly granularity, 1 February – 30 June 2026).	7

List of Tables

1	Key technologies and resources, with alternatives and rationale.	II
2	Risk register for the proposed project.	III
3	Objectives mapped to preliminary artefacts in the supporting repository. . .	III

Abstract

User privacy is increasingly regulated by international standards and legal instruments, yet existing artificial intelligence (AI) tools that analyse privacy policies remain disconnected from these standards and produce no quantitative, interoperable indicators of risk. This proposal sets out a five-month MSc project that addresses this gap by developing an AI-driven framework for quantifying user privacy risk in line with ISO/IEC, NIST, IEEE and GDPR requirements. The project will (i) translate selected standards clauses into measurable indicators, (ii) define multi-level metrics across user, system and organisation views, (iii) combine a fine-tuned PrivacyBERT clause classifier with a Bayesian probabilistic risk model, and (iv) validate the prototype on synthetic logs and public breach datasets (ENISA, Privacy Rights Clearinghouse). The output is a validated proof-of-concept tool, a draft metric set, and a roadmap towards a fuller standards-aligned framework. Initial work in the supporting repository, including standards-to-control extraction and a reproducible Phase 3 freeze, demonstrates the technical feasibility of the proposed plan.

1 Introduction and Background

The protection of personal data has become a defining technical and regulatory concern of the past decade. Regulators in the European Union, the United Kingdom and the United States have responded with overlapping but heterogeneous instruments, including the General Data Protection Regulation (European Parliament and Council of the European Union 2016), the NIST Privacy Framework (National Institute of Standards and Technology 2020), the family of ISO/IEC 27000-series standards (International Organization for Standardization 2022; International Organization for Standardization 2019; International Organization for Standardization 2011; International Organization for Standardization 2017), and most recently the EU AI Act (European Parliament and Council of the European Union 2024). These instruments place increasing pressure on *measurable* privacy assurance: not only that controls exist, but that their effectiveness can be evaluated and compared.

The stakeholders affected are diverse. **Data subjects** need understandable, comparable indicators of how a given service treats their information. **Data controllers and processors** must demonstrate compliance to auditors and regulators, often across several overlapping standards simultaneously. **Regulators and auditors** need objective evidence to support enforcement decisions. **Researchers** require reproducible benchmarks for new privacy-preserving techniques. Each of these stakeholders is currently underserved.

The core problem this project addresses is the disconnect between two communities of work. On one side, AI-based privacy-policy analysis tools such as Polisis (Harkous et al. 2018) and PrivacyBERT-LSTM (Muralitharan and Arumugam 2024) can classify clauses with high accuracy but stop short of producing standards-aligned, quantitative risk scores. On the other side, standards and regulatory frameworks define rich principles (consent, data minimisation, purpose limitation, encryption, third-party sharing) but provide no operational

metrics to evaluate them at scale. The recent IEEE survey by Arshad and Asghar (2024) confirms that no current approach integrates AI-driven privacy analysis with standards-based compliance measurement, and identifies multi-level quantification as an open challenge.

The project is important because measurable privacy risk underpins three concrete benefits. For data subjects, comparable scores improve transparency and informed consent. For organisations, multi-level metrics support targeted remediation and reduce audit cost. For regulators, calibrated risk indicators enable evidence-based enforcement and post-incident analysis using public breach corpora such as ENISA’s Threat Landscape (European Union Agency for Cybersecurity (ENISA) 2024) and the Privacy Rights Clearinghouse chronology (Privacy Rights Clearinghouse 2024).

Building on prior work, the project takes existing strengths — transformer-based clause classification, probabilistic risk modelling and standards taxonomies — and integrates them into a single multi-level pipeline. The central research question is therefore: *To what extent can a transformer-based clause classifier, coupled with a Bayesian probabilistic scorer and a clause-to-standard traceability map, produce calibrated, multi-level privacy-risk indicators that align with ISO/IEC, NIST and GDPR requirements?*

2 Aims and Objectives

Overall aim. To design, implement and validate an AI-driven, standards-aligned framework for quantifying user privacy risk that combines transformer-based clause classification with Bayesian probabilistic scoring, evaluated against synthetic and publicly available breach data.

Objectives. The aim is decomposed into five SMART objectives. The annotations (*S, M, A, R, T*) indicate, respectively, that each objective is *specific, measurable, achievable, relevant* to the MSc programme, and *time-bound*.

O1 – Standards-to-metrics mapping.

Extract candidate privacy controls from at least four standards families (GDPR, ISO/IEC 27001/27701/29100/29151, NIST Privacy Framework, NIST AI RMF) and map them to a normalised indicator catalogue. (*S*) Targets a defined corpus of clauses; (*M*) success measured by traceability coverage ($\geq 90\%$ of selected clauses mapped to at least one indicator); (*A*) achievable using existing parsers and the standards corpus already in the project repository; (*R*) provides the foundation for all later phases; (*T*) delivered by end of Month 1 (28 February 2026).

O2 – Multi-level metric definition and synthetic data.

Specify metric formulas at user, system and organisation levels, generate a synthetic event dataset and run baseline scoring. (*S*) Three explicit metric levels with documented

formulas; (*M*) baseline scoring produces interpretable distributions on at least 1,000 synthetic events; (*A*) reuses Phase 1 indicator catalogue; (*R*) supports validation in later phases; (*T*) delivered by end of Month 2 (31 March 2026).

O3 – Clause classification model.

Fine-tune a PrivacyBERT-style transformer on the OPP-115 corpus (Wilson, Schaub, Dara, et al. 2016; Wilson, Schaub, Sadeh, et al. 2016) and Polisis-derived data, achieving competitive classification performance on the standard categories. (*S*) Targets the 10 OPP-115 high-level categories; (*M*) macro-F1 ≥ 0.70 on a held-out test split, with calibration reported; (*A*) achievable on a single CUDA-class GPU; (*R*) produces clause-level evidence consumed by O4; (*T*) delivered by end of Month 3 (30 April 2026).

O4 – Bayesian risk integration.

Combine clause classifier outputs with a Bayesian probabilistic risk model that scores user-, system- and organisation-level risk using the Phase 2 metrics. (*S*) A single risk pipeline with documented inputs/outputs; (*M*) produces calibrated posterior distributions and bootstrap confidence intervals on a held-out evaluation set; (*A*) builds on pgmpy-style toolkits and the existing Phase 3 freeze; (*R*) addresses the core research question; (*T*) delivered by mid-Month 4 (15 May 2026).

O5 – Validation, benchmarking and final report.

Benchmark the prototype against defined metrics on real and synthetic data and deliver a validated tool plus the final MSc report. (*S*) Validation report comparing the integrated model against logistic-regression and naive-Bayes baselines; (*M*) statistically significant improvement on at least one calibration metric (Brier score or ECE) with bootstrap CIs; (*A*) ablation pipelines already exist in the project repository; (*R*) satisfies MSc assessment criteria; (*T*) final submission on 30 June 2026.

Intermediate, enabling deliverables include a reproducible build pipeline, a unit-test suite covering parsers and chunking, and a small Streamlit/Flask demonstration interface for the validation phase.

3 Literature Review

The proposed framework sits at the intersection of four research strands: privacy-policy natural language processing (NLP), privacy quantification and breach analytics, standards and regulatory frameworks, and probabilistic risk modelling. This review summarises and critiques each strand, then identifies the gap that motivates the project.

3.1 AI for privacy-policy analysis

A first generation of work focused on automatically classifying privacy-policy clauses. The OPP-115 corpus introduced by Wilson, Schaub, Dara, et al. (2016) provides 115 manually

annotated policies across ten high-level data-practice categories and remains the de-facto benchmark for the field. Building on this, Harkous et al. (2018) introduced *Polisis*, a hierarchical neural classifier that demonstrated the feasibility of large-scale automated policy analysis and powers downstream tools such as PriBot. More recently, Muralitharan and Arumugam (2024) proposed a PrivacyBERT-LSTM hybrid that improves on earlier baselines for sensitive-information detection by combining transformer encoders with sequence modelling. These approaches all benefit from the broader maturation of contextual language models, particularly BERT (Devlin et al. 2019).

The shared limitation of this strand is scope. The output is invariably a categorical label or a per-clause probability; none of these systems produce a *calibrated* risk score, nor do they trace clauses back to specific standards or regulatory obligations. As a result, their outputs are useful for transparency tools but not directly consumable by auditors or by quantitative risk frameworks.

3.2 Privacy quantification and breach analytics

The second strand attempts to quantify privacy at the level of users, systems or organisations. The recent IEEE survey by Arshad and Asghar (2024) provides the most comprehensive synthesis to date, cataloguing dozens of candidate metrics and noting that the field remains fragmented across academic communities (k-anonymity-style metrics in databases, differential privacy in statistics, risk indicators in cyber-security). Empirical breach studies, in turn, draw on data from ENISA’s Threat Landscape (European Union Agency for Cyber-security (ENISA) 2024) and the Privacy Rights Clearinghouse chronology (Privacy Rights Clearinghouse 2024) to characterise incident frequency and severity. Solove (2006) provides the conceptual taxonomy of privacy harms that underpins much of this measurement work.

The critique here is twofold: existing quantification work tends to operate at a single level of abstraction (user *or* organisation), and it rarely connects measurement to standards-defined obligations. Breach datasets are valuable but inherently retrospective; they describe failures rather than the latent risk profile of a system in operation.

3.3 Standards and regulatory frameworks

A third body of literature codifies privacy as obligations rather than measurements. The GDPR (European Parliament and Council of the European Union 2016) introduced principles such as data minimisation, purpose limitation and lawfulness as binding requirements. The ISO/IEC family (International Organization for Standardization 2022; International Organization for Standardization 2019; International Organization for Standardization 2011; International Organization for Standardization 2017) translates these principles into auditable controls, while the NIST Privacy Framework (National Institute of Standards and Technology 2020) and the NIST AI Risk Management Framework (National Institute of Standards and Technology 2023) offer outcome-oriented profiles that complement ISO’s

control-based view. The EU AI Act (European Parliament and Council of the European Union 2024) extends the regulatory perimeter to algorithmic systems themselves.

These instruments are normatively rich but operationally ambiguous: “appropriate technical and organisational measures” (GDPR Art. 32) is not directly measurable. Bridging the gap between normative obligations and quantitative indicators is precisely the task this project takes on.

3.4 Probabilistic risk modelling

The fourth strand is probabilistic risk modelling, dominated by Bayesian networks and related graphical models (Pearl 1988; Koller and Friedman 2009). Bayesian methods are attractive for privacy risk because they accommodate partial evidence, support hierarchical structure (user $\rightarrow$ system $\rightarrow$ organisation) and produce calibrated posteriors with explicit uncertainty. Calibration metrics such as expected calibration error (ECE), Brier score and bootstrap confidence intervals are well established in the broader machine-learning literature. Lighter alternatives such as logistic regression and naive Bayes serve as natural baselines and ablations.

3.5 Synthesis and gap

Across these four strands, no single piece of work integrates clause-level NLP, standards-traceable indicators and a multi-level probabilistic risk model. Harkous et al. (2018) and Muralitharan and Arumugam (2024) provide classification but not quantification; Arshad and Asghar (2024) surveys quantification but does not deliver an implemented standards-aligned tool; standards bodies define obligations but not metrics. This proposal targets exactly that intersection, and uses the OPP-115, Polisis, ENISA and PRC datasets as evaluation substrates.

4 Technologies and Resources

The project’s technology choices are summarised in Table 1 together with the principal alternative considered for each role and the rationale for selection. The selection prioritises reproducibility, free or low-cost access for an MSc project, and compatibility with the existing project repository.

A high-level view of how these components interact is shown in Figure 1. Privacy policies are tokenised and passed to the PrivacyBERT classifier; clause-level posteriors are combined with the standards-to-indicator map and fed into the Bayesian scorer, which emits multi-level risk distributions used for benchmarking and validation.

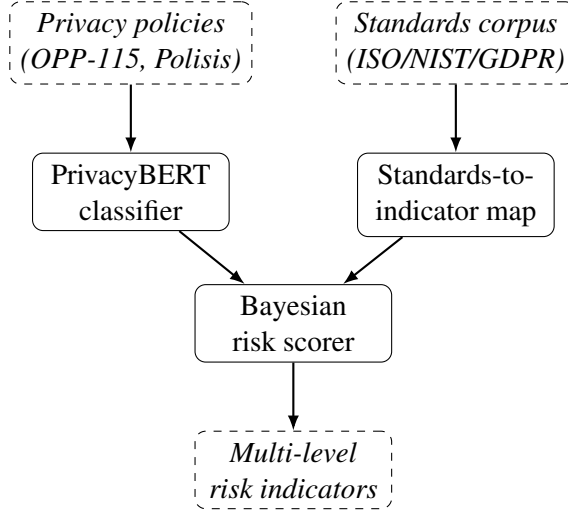


Figure 1: High-level architecture of the proposed framework.

5 Method and Work Plan

5.1 Research method

The project follows a *design-science research* (DSR) methodology: the central artefact is the integrated risk-quantification tool, and each phase delivers an evaluable increment. Evaluation is mixed-methods: classification quality is assessed quantitatively (macro-F1, calibration, bootstrap CIs); standards traceability is assessed qualitatively against documented clauses; end-to-end utility is assessed through a small validation study on synthetic and public breach data. Iteration between phases is explicit — findings from validation in O5 feed back into the metric definitions of O2 and the model architecture of O3–O4.

The four phases mirror the structure already established in the supporting repository (see also Table 3 in the appendix):

1. **Phase 1 (Month 1) – Standards-to-metrics mapping.** Parse standards documents into normalised controls; chunk for retrieval; produce the indicator catalogue. *Milestone M1*: mapping artefact frozen.
2. **Phase 2 (Month 2) – Multi-level metrics and synthetic data.** Define formulas; generate synthetic events; run baseline scoring; partially implement organisation-level indicators. *Milestone M2*: draft metrics and synthetic dataset frozen.
3. **Phase 3 (Month 3 – mid-Month 4) – Prototype build.** Fine-tune the clause classifier; integrate the Bayesian scorer; produce a reproducible *freeze* bundle including LR and NB ablations. *Milestone M3*: prototype frozen.
4. **Phase 4 (mid-Month 4 – Month 5) – Validation and reporting.** Benchmark on real and synthetic data; produce calibration plots and bootstrap CIs; write the final report. *Milestone M4*: validated tool and final report.

5.2 Schedule

The schedule is shown in Figure 2. Weekly granularity is used so that intermediate deliverables remain trackable. A thesis-writing bar overlaps Phases 3 and 4 to reflect that the report is drafted continuously.

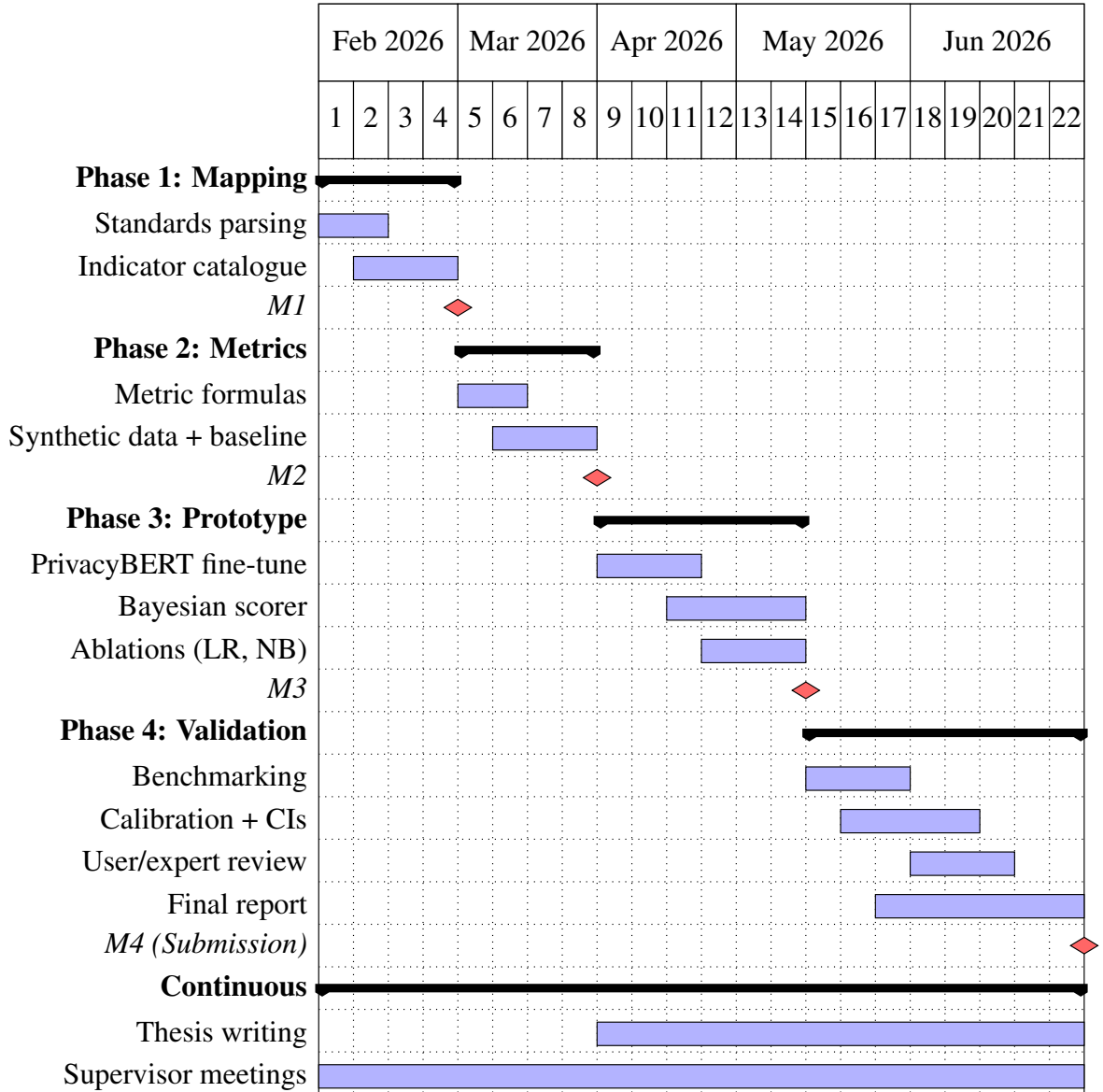


Figure 2: Project schedule (weekly granularity, 1 February – 30 June 2026).

5.3 Risk analysis and contingencies

Major risks and mitigations are listed in Table 2. Likelihood and impact are scored qualitatively (L/M/H).

5.4 Progress to date and feasibility

A supporting code repository (PrERT-CNM-v4) has been used to prototype the pipeline and de-risk the proposal. Concretely, regulation-specific parsers and 16 KiB-safe chunking al-

ready produce normalised control sets at `artifacts/phase-1/` for GDPR, ISO/IEC 27001/27002/27005 12 and NIST Privacy Framework; Phase 2 baseline scoring outputs and synthetic events sit at `artifacts/phase-2/`; a Phase 3 acceptance freeze with calibration, bootstrap-CI and Bayesian-risk JSON outputs sits at `artifacts/phase-3-freeze/`, alongside ablation directories `phase-3-logreg/` and `phase-3-nb/`. Unit tests under `tests/` cover parsing, chunking and Phase 2–4 pipeline behaviour. This preliminary work demonstrates that each phase of the proposal is technically feasible within the five-month window; the remaining effort is concentrated on the integration, validation and reporting tasks captured by O4 and O5.

6 Ethics, Legal, Data Protection and Safety

The project has been designed to minimise ethical and legal risk. The key considerations are summarised below.

Human-subjects involvement. The project does *not* recruit human participants and does not collect any personal data directly. All training and evaluation data are pre-existing public corpora (OPP-115, Polisis-derived data) or synthetic events generated programmatically. The project therefore falls into the lowest-risk Kingston University ethics tier (self-certification) rather than full ethics-committee review.

Data protection (GDPR, UK GDPR). Synthetic events contain no real personal data; they are generated from clause-level templates. Public breach datasets (European Union Agency for Cybersecurity (ENISA) 2024; Privacy Rights Clearinghouse 2024) contain incident-level summaries rather than identifiable records. No personal data is therefore processed by the project, and Article 6 lawful-basis analysis defaults to “not applicable”. Where any low-risk processing occurs (e.g. supervisor email correspondence), it is covered by Kingston University’s existing data-protection notice. The principle of *data minimisation* (GDPR Art. 5(1)(c)) is applied to all stored artefacts.

Licensing and copyright. OPP-115 is released by the Usable Privacy project for research use; the project will retain the original licence and attribution. ISO/IEC standards documents are used in their licensed form held by the author for personal study; only short excerpts and clause identifiers (rather than full text) are reproduced in any output. Polisis-derived data is used in line with the original authors’ terms of use. NIST documents and the GDPR text are public-domain or open-licensed and are cited accordingly.

Algorithmic safety and dual-use. A foreseeable harm is *false assurance*: an organisation may treat a low risk score as evidence of compliance when the underlying model is poorly calibrated. The proposal mitigates this by (i) reporting calibration metrics (Brier score, ECE)

alongside point predictions, (ii) reporting bootstrap confidence intervals on all aggregate scores, and (iii) including an explicit “limitations” section in any published output. The system is positioned as a *decision-support* tool rather than a compliance certificate. The recent EU AI Act (European Parliament and Council of the European Union 2024) reinforces this framing: tools that influence compliance decisions sit close to the “high-risk” boundary and require transparency about their statistical behaviour.

Information security. Secrets (e.g. Chroma Cloud API keys) are handled exclusively through a local `.env` file and are excluded from version control. Source code is published under the project’s MIT licence; trained model checkpoints, if shared, will be stripped of any environment-specific configuration.

7 Conclusion

This proposal sets out a five-month MSc project to deliver a standards-aligned, AI-driven framework for quantifying user privacy risk. The framework integrates a transformer-based clause classifier, a Bayesian probabilistic scorer and an explicit standards-to-indicator map, evaluated on synthetic events and public breach data. Five SMART objectives, a phase-by-phase Gantt schedule and a documented risk register together establish the project as feasible within the available window. Preliminary work in the supporting repository demonstrates that the major technical components — regulation parsing, multi-level metric definition and a reproducible Phase 3 freeze — are already operational, focusing the remaining effort on integration, validation and reporting. The expected contribution is the first standards-aligned, multi-level privacy risk quantification model with calibrated uncertainty, together with a clear roadmap for scaling the prototype into a comprehensive privacy-assurance framework.

References

- Arshad, Rahat and Mamoon N. Asghar (2024). “Characterisation and Quantification of User Privacy: Key Challenges, Regulations, and Future Directions”. In: *IEEE Communications Surveys and Tutorials*.
- Devlin, Jacob, Ming-Wei Chang, Kenton Lee, and Kristina Toutanova (2019). “BERT: Pre-training of Deep Bidirectional Transformers for Language Understanding”. In: *Proceedings of NAACL-HLT*. ACL, pp. 4171–4186.
- European Parliament and Council of the European Union (2016). *Regulation (EU) 2016/679 (GDPR) on the Protection of Natural Persons with Regard to the Processing of Personal Data and on the Free Movement of Such Data*. Official Journal of the European Union, L 119/1.
- (2024). *Regulation (EU) 2024/1689 Laying Down Harmonised Rules on Artificial Intelligence (AI Act)*. Official Journal of the European Union.
- European Union Agency for Cybersecurity (ENISA) (2024). *ENISA Threat Landscape 2024*. ENISA Report. URL: <https://www.enisa.europa.eu/publications/enisa-threat-landscape-2024>.
- Harkous, Hamza, Kassem Fawaz, Rémi Lebret, Florian Schaub, Kang G. Shin, and Karl Aberer (2018). “Polisis: Automated Analysis and Presentation of Privacy Policies Using Deep Learning”. In: *Proceedings of the 27th USENIX Security Symposium (SEC’18)*. Baltimore, MD, USA: USENIX Association, pp. 531–548.
- International Organization for Standardization (2011). *ISO/IEC 29100:2011 Information Technology – Security Techniques – Privacy Framework*. ISO. Geneva.
- (2017). *ISO/IEC 29151:2017 Information Technology – Security Techniques – Code of Practice for Personally Identifiable Information Protection*. ISO. Geneva.
- (2019). *ISO/IEC 27701:2019 Security Techniques – Extension to ISO/IEC 27001 and ISO/IEC 27002 for Privacy Information Management*. ISO. Geneva.
- (2022). *ISO/IEC 27001:2022 Information Security, Cybersecurity and Privacy Protection – Information Security Management Systems – Requirements*. ISO. Geneva.
- Koller, Daphne and Nir Friedman (2009). *Probabilistic Graphical Models: Principles and Techniques*. Cambridge, MA: MIT Press.
- Muralitharan, J. and C. Arumugam (2024). “Privacy BERT-LSTM: a Novel NLP Algorithm for Sensitive Information Detection in Textual Documents”. In: *Neural Computing and Applications* 36, pp. 15439–15454.
- National Institute of Standards and Technology (2020). *NIST Privacy Framework: A Tool for Improving Privacy Through Enterprise Risk Management, Version 1.0*. NIST. Gaithersburg, MD.
- (2023). *Artificial Intelligence Risk Management Framework (AI RMF 1.0)*. NIST AI 100-1. NIST. Gaithersburg, MD. URL: <https://www.nist.gov/itl/ai-risk-management-framework>.

- Pearl, Judea (1988). *Probabilistic Reasoning in Intelligent Systems: Networks of Plausible Inference*. San Francisco, CA: Morgan Kaufmann.
- Privacy Rights Clearinghouse (2024). *Chronology of Data Breaches*. Online dataset. URL: <https://privacyrights.org/data-breaches>.
- Solove, Daniel J. (2006). “A Taxonomy of Privacy”. In: *University of Pennsylvania Law Review* 154.3, pp. 477–564.
- Wilson, Shomir, Florian Schaub, Aswarth Abhilash Dara, Frederick Liu, Sushain Cherivirala, Pedro Giovanni Leon, Mads Schaarup Andersen, Sebastian Zimmeck, Kanthashree Mysore Sathyendra, N. Cameron Russell, Thomas B. Norton, Eduard Hovy, Joel Reidenberg, and Norman Sadeh (2016). “The Creation and Analysis of a Website Privacy Policy Corpus”. In: *Proceedings of the 54th Annual Meeting of the Association for Computational Linguistics (ACL)*. Berlin, Germany: ACL, pp. 1330–1340.
- Wilson, Shomir, Florian Schaub, Norman Sadeh, et al. (2016). *OPP-115 Privacy Policy Corpus, Version 1.0*. Usable Privacy Project. URL: <https://www.usableprivacy.org/data>.

A Appendix: Mapping of Objectives to Existing Repository Artefacts

Table 3 maps each objective to concrete preliminary artefacts already present in the supporting repository. These are cited as feasibility evidence; the proposal frames remaining work in terms of integration, validation and reporting.

Table 1: Key technologies and resources, with alternatives and rationale.

Role	Selected	Alternatives considered / rationale
Language and core stack	Python 3.11	Java, Go — rejected: weaker mature NLP and probabilistic-modelling ecosystems.
Clause classifier	PrivacyBERT / DistilBERT fine-tune (Devlin et al. 2019; Muralitharan and Arumugam 2024)	Full BERT-large, GPT-class APIs — rejected: GPU/cost constraints and reduced reproducibility for closed APIs.
Risk model	Bayesian network via pgmpy (Koller and Friedman 2009)	Logistic regression, Naive Bayes — retained as ablation baselines rather than primary model.
Vector store / retrieval	Chroma Cloud (free tier)	FAISS (local), Pinecone — chosen for managed infrastructure and reproducibility from any machine.
Datasets (training)	OPP-115 (Wilson, Schaub, Dara, et al. 2016), Polisis-derived corpus (Harkous et al. 2018)	Hand-curated policy sets — rejected: insufficient scale and inconsistent labels.
Datasets (evaluation)	ENISA Threat Landscape (European Union Agency for Cybersecurity (ENISA) 2024), PRC chronology (Privacy Rights Clearinghouse 2024), synthetic events	Single source — rejected: insufficient diversity for cross-validation.
Standards corpus	Local copies of ISO/IEC, NIST and GDPR documents (International Organization for Standardization 2022; International Organization for Standardization 2019; International Organization for Standardization 2011; International Organization for Standardization 2017; National Institute of Standards and Technology 2020; National Institute of Standards and Technology 2023; European Parliament and Council of the European Union 2016)	Online lookup — rejected: rate-limit and version drift.
Compute	Local CUDA GPU (16 GB)	Cloud GPU (Colab Pro, AWS) — retained as fallback if local compute fails.
Evaluation / testing	pytest, scikit-learn, bootstrap CIs	Bespoke test code — rejected: maintenance overhead.
Demonstration interface	Flask / Streamlit web app	Jupyter-only demo — rejected: not stakeholder-facing.
Version control / CI	Git, GitHub	Self-hosted — rejected: marginal benefit for an MSc-scale project.

Table 2: Risk register for the proposed project.

Risk	L	I	Mitigation
Dataset access loss (OPP-115/Polisis mirror)	L	H	Maintain a local snapshot under data/raw/; rely on Phase 1 chunked controls already on disk.
Local GPU failure during Phase 3 fine-tuning	M	M	Fall back to Google Colab Pro; checkpoint every epoch to disk.
Scope creep on ecosystem-level indicators	H	M	Hold ecosystem-level work as “future work”; document only in the conceptual scope.
OPP-115 label noise harming F1	M	M	Report per-category metrics; use macro-F1 and calibration rather than accuracy alone.
Supervisor unavailability around milestones	M	L	Pre-book milestone reviews; keep written summaries to enable async feedback.
Ethics / data-handling delay	L	M	Use only public, properly licensed datasets; avoid any human-subjects work (see §6).
Calibration metrics fail to improve over baselines	M	H	Pre-register baseline targets; if not met, reframe contribution around the standards-traceability artefact (O1) and metric set (O2).

Table 3: Objectives mapped to preliminary artefacts in the supporting repository.

Objective	Preliminary artefact (path)
O1 – Standards-to-metrics mapping	artifacts/phase-1/controls_*.jsonl, chunks_*.jsonl; parsers under src/prert/extract/.
O2 – Multi-level metrics, synthetic data	artifacts/phase-2/metric_specs.jsonl, baseline_scores.jsonl, synthetic_events.jsonl.
O3 – PrivacyBERT classifier	Phase 3 training pipeline under scripts/run_phase3_baseline.py; OPP-115 processor in scripts/process_opp115_for_phase2.py.
O4 – Bayesian risk integration	artifacts/phase-3-freeze/bayesian_risk_*.json, calibration_*.json, bootstrap_ci_*.json; ablations under phase-3-logreg/, phase-3-nb/.
O5 – Validation and final report	artifacts/phase-4/; web/demo entry point scripts/run_phase4_web.py; tests under tests/test_phase4_*.py.